

Data Governance & Privacy Assessment — UC-2041

Commercial Banking Policy Knowledge Assistant · First line: Commercial Banking Operations · Reviewed: Data Governance Office

Scope of Data

The use case retrieves from a curated collection of the Bank's **internal commercial credit policy and procedure manuals**. No customer, applicant, account, or transaction data is present in the retrieval corpus or in user prompts.

Privacy Determination

- **PII processed: None.** A DPIA screening was completed and concluded no personal data is in scope; a full DPIA is therefore not required.
- Prompts and completions remain within the Bank's AWS VPC via the Bedrock in-region endpoint (see AIBOM FM-0007). No data egress to the model provider; no training on Bank data.

Controls in Place

- Input filtering blocks prompts containing customer identifiers; flagged prompts are refused and logged.
- Output redaction is not required (no sensitive data in scope) but output logging is retained for audit.
- Access restricted to authenticated Commercial Banking staff via SSO; per-role entitlement.

Residual Risk

Low. The absence of PII and the internal-only, informational nature of the use case remove the primary data-leakage and privacy exposures. Re-assessment is triggered if the corpus or prompt scope is expanded to include customer data (see monitoring plan re-tiering trigger).